

Table of Contents

Cisco Secure Workload — NIS2 Directive

Reference Design | Essential & Important Entities (EU)

Version: 1.0 | **Standard:** Directive (EU) 2022/2555 — NIS2 | **Transposition deadline:** 17 October 2024 | **Environment:** Hybrid

Reader's Guide

Who this is for. Operators of essential or important entities in scope of NIS2 across the EU — energy, transport, banking, financial market infrastructure, health, drinking water, waste water, digital infrastructure, ICT service management (B2B), public administration, space, postal/courier, waste management, chemicals, food, manufacture of critical products, digital providers, research — together with the CISOs and security architects preparing those entities for their national competent authority's review.

Questions this reference design helps you answer:

- *Article 21(2)(a) — risk-analysis and information-system security policies: do my policies translate into something a workload actually does, or do they live only in a policy document?*
- *Article 21(2)(b) — incident handling: when an incident occurs, what's my workload-level evidence pack, and can I assemble it inside the early-warning window of 24 hours?*
- *Article 21(2)(d) — supply chain security: do I know what my workloads are actually doing with each of my suppliers' endpoints — independent of the SBOM, the questionnaire, and the contract?*
- *Article 21(2)(e) — security in network and information systems acquisition, development and maintenance, including vulnerability handling and disclosure: when a CVE drops on a library inside one of my containers, can I show which workloads are exposed and which paths attackers could traverse to reach them, on the same day?*
- *Article 21(2)(f) — policies and procedures to assess the effectiveness of cybersecurity risk-management measures: what do I show a competent authority as evidence that the measures are operating effectively, not just implemented?*
- *Article 21(2)(i) — human resources security, access control and asset management: where is the asset-management telemetry that feeds the rest of the programme?*
- *Article 21(2)(j) — multi-factor authentication, secured voice/video and emergency communications, secured workload-to-workload channels: how do I demonstrate that workload-to-workload communication is restricted to what is authorised?*

- *Article 23 — reporting: when something major happens, can I meet the 24h early-warning, 72h notification, and 1-month final-report cadence with the same evidence pack each time?*
- *If senior management is personally liable under Article 20(1), what artefact do they look at to discharge that liability with confidence?*

What you'll need. Your entity's NIS2 classification (essential vs. important — affects supervisory regime), your asset inventory, the list of services your management body has identified as in scope, your current incident-response reference design, your current supplier register, and the contact details of your competent authority and CSIRT.

Where to start. Section 1 to align on what NIS2 actually requires (it is broader and less prescriptive than DORA); section 2 if you're mapping CSW to the ten Article 21(2) measures one-by-one; section 4 if reporting under Article 23 is the open item; section 5 if supply-chain visibility is the gap; section 7 if you need the auditor / competent-authority response cookbook.

Important. NIS2 places personal liability on management bodies (Art. 20(1)) and explicit training obligations on them (Art. 20(2)). Nothing in this reference design substitutes for that governance. CSW gives the management body the *evidence* it needs to discharge that accountability with confidence; it does not discharge it on the body's behalf.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope

- ❑ ADM-imported rules refined; Simulation run ≥ 1 week
- ❑ Change tickets for false-positive fixes; exception register updated
- ❑ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ❑ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ❑ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ❑ SIEM integration verified (sample events)
- ❑ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Art. 21(2) risk-management mapping with continuous workload evidence
- Art. 23 incident timeline support (24h/72h/1-month)
- Art. 21(2)(d) supply-chain egress visibility

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

NIS2 replaces NIS1 and applies to a far broader set of sectors and entities. It establishes:

- A **two-tier scope**: essential entities (more intensive supervision and higher fines) and important entities (lighter ex-post supervision).
- A **risk-management framework** in Article 21(2) listing 10 cybersecurity measures every in-scope entity must implement.
- A **harmonised reporting regime** in Article 23 with three deadlines: 24-hour early warning, 72-hour incident notification, 1-month final report.
- **Management body accountability** in Article 20 with personal liability and a training obligation.
- **Supervisory and enforcement** regimes in Articles 32–33 with fines up to €10m or 2% of worldwide turnover (essential entities).

CSW is most directly relevant to seven of the ten Article 21(2) measures and to the technical evidence layer underneath Article 23 reporting. Identity, awareness training, cryptography, and HR-process controls are addressed by complementary parts of the Cisco Security portfolio (Duo, Identity Services Engine, Umbrella) and by the customer's own programme.

2. Article 21(2) — The Ten Measures

NIS2 is *measure-based* rather than control-prescriptive. Each measure below is paraphrased; consult the official text and any implementing acts for the binding wording.

(a) Policies on risk analysis and information system security

What it requires. Documented risk analysis and policies for information-system security, proportionate to the risk.

CSW Implementation:

Step 1: Convert each policy clause that describes a workload behaviour into a CSW Intent

- "PII workloads must not communicate with the internet" → DENY policy
- "Production must not call non-production" → DENY policy
- "Plaintext protocols are not used for sensitive data" → DENY policy

Step 2: For each Intent, run in Simulation

- Simulation surfaces the gap between policy-on-paper and reality

Step 3: Resolve the gap

- Either: change the application (close the gap)
- Or: document a time-bound exception in the workspace notes
- Either way, the policy is now grounded in observable behaviour

Evidence: Workspace export showing each policy Intent with in-scope workload count, current Simulation status, and exception list.

(b) Incident handling

What it requires. Capability to detect, respond to and recover from incidents.

CSW Implementation: see §3 (Detection) and §4 (Reporting Evidence).

Evidence: Detection rule catalogue (with last-modified dates), SIEM forwarding configuration, mean-time-to-detect by service.

(c) Business continuity, including backup management and crisis management

What it requires. Recovery, backup, and crisis management.

CSW position: Out of scope for backup/recovery primitives. CSW contributes by:

- providing the segmentation that limits incident blast radius (so fewer assets need recovery), and
- preserving forensic flow data through a recovery event so post- incident review (Art. 21(2)(b)) is grounded in evidence.

Evidence: Containment policy applied per IBF; pre/post recovery flow comparison.

(d) Supply chain security

What it requires. Aspects related to the supply-chain security relationship between each entity and its direct suppliers / service providers.

CSW Implementation: see §5.

(e) Security in network and information systems acquisition, development and maintenance, including vulnerability handling and disclosure

What it requires. Secure development, vulnerability management, and coordinated disclosure handling.

CSW Implementation:

Step 1: Continuous workload vulnerability inventory

CSW UI → Vulnerabilities → Workloads

Filter: severity ≥ High AND ibf=true → priority remediation queue

Output: per-workload CVE, CVSS, exploit availability, EPSS

Step 2: Pre-deployment vulnerability gating

→ CI/CD gate: query CSW API for CVE exposure of the candidate image

→ Block deployment if the image introduces a Critical/Exploitable CVE not present in production already

Step 3: Vulnerability-to-flow correlation

→ For each High/Critical CVE: which workloads are affected, what other workloads talk to them, what's the actual reachable attack path?

→ This is the artefact your competent authority and ENISA will increasingly expect under Art. 21(2)(e) and the CRA-aligned RTS.

Evidence: Weekly vulnerability backlog by criticality, aged; CI/CD gate audit log; CVE-to-attack-path report per major vulnerability event.

(f) Policies and procedures to assess the effectiveness of cybersecurity risk-management measures

What it requires. Demonstrate that the measures are *effective*, not just present.

CSW Implementation — the "effectiveness" pack:

For each Article 21(2) measure CSW supports, produce one piece of *operating effectiveness* evidence per quarter:

- Measure (a): policy-vs-observed Simulation diff (gap closure rate)
- Measure (b): MTTD trend per service, MTTR trend per incident class
- Measure (d): supplier egress drift count (new endpoints per quarter)
- Measure (e): CVE backlog trend by severity, mean-time-to-patch
- Measure (i): workloads without required asset labels (drift count)
- Measure (j): denied workload-to-workload connections per period

Bundle into a quarterly "NIS2 Article 21(2)(f) effectiveness pack" that the management body reviews under Art. 20(1).

Evidence: Quarterly effectiveness pack (PDF/CSV).

(g) Basic cyber hygiene practices and cybersecurity training

CSW position: Training is out of scope. Hygiene baseline (patch status, configuration drift, dormant accounts) — CSW contributes patch and process telemetry to populate the hygiene dashboard the management body uses to confirm the baseline is met.

Evidence: Patch posture report; process anomaly summary.

(h) Policies and procedures regarding the use of cryptography and, where appropriate, encryption

CSW position: CSW does not provide cryptographic primitives. It contributes by enforcing policies that *require* encrypted protocols and *deny* plaintext (HTTP, FTP, Telnet, plain LDAP) on sensitive scopes (see Article 21(2)(a) implementation above).

Evidence: Policy export showing plaintext-protocol DENY rules in force on sensitive scopes.

(i) Human resources security, access control and asset management

What it requires (asset-management portion). Maintain a current asset inventory and apply access control proportionate to risk.

CSW Implementation — asset-management baseline:

Step 1: Sensor coverage on every server, VM and container

Step 2: Mandatory label set:

```
service:      [in-scope service identifier]
data_class:   personal | sensitive | confidential | public
nis2_in_scope: true | false
owner:        [team]
environment:  prod | non-prod
```

Step 3: Daily drift report

- New workloads without labels = onboarding gap
- Removed workloads = offboarding evidence

Evidence: Per-service inventory export; label-coverage trend.

(j) Use of multi-factor authentication or continuous authentication solutions, secured voice, video and text communications and secured emergency communication systems within the entity, where appropriate

CSW position: MFA itself is provided by Cisco Duo or equivalent. CSW addresses a separate workload-to-workload secured-communication control by:

- enforcing identity- and label-based segmentation for authorised workload paths, and
- denying connection paths that the policy doesn't explicitly allow.

Evidence: Segmentation workspace export; deny-by-default policy proof.

3. Article 21(3) — All-Hazards Approach (Detection)

NIS2 expects the measures above to be applied with an "all-hazards" mindset. CSW contributes the workload-anomaly detection layer:

Layer 1 – Behavioural rules (signature-style)

CSW UI → Defend → Forensics → Rules

Cover: privilege escalation, persistence, lateral movement, credential access, defence evasion, exfiltration

Layer 2 – Conversation-graph anomalies

Auto-flag new edges in the dependency graph (workload starts talking to something it never talked to before)

Auto-flag changes in port/protocol distribution per workload

Layer 3 – Vulnerability + reachability fusion

When a new exploit-in-the-wild CVE drops, automatically intersect CVE-affected workloads × current reachable inbound paths

→ Prioritised "attackable today" list

All three feed the SOC SIEM with NIS2-relevant labels so they roll into reporting under Art. 23 with the right context.

4. Article 23 — Reporting

NIS2 establishes a single reporting flow with three deadlines (subject to Member State implementing law and any further ENISA guidance):

Phase	Deadline	Required content
Early warning	Within 24 h of becoming aware of a significant incident	Initial assessment, indication of cross-border / malicious origin, request for cross-border assistance if needed
Incident notification	Within 72 h of becoming aware	Updated assessment, indicators of compromise, severity & impact estimates
Final report	Within 1 month of the notification	Detailed description, root cause, remediation, cross-border impact summary

Plus an **intermediate update** on request from the competent authority or CSIRT.

CSW Implementation — Reporting Evidence Pack:

For each significant incident, assemble from CSW:

- (1) Affected workload set
 - Inventory query: hostnames, IPs, OS, service labels, ownership
- (2) Time-anchored flow record
 - Source, destination, port, byte counts, timestamps
 - Geographic context for the cross-border indicator
- (3) Process activity record
 - Every process spawned on affected workloads in the window
- (4) Software footprint at time of incident
 - Package list, CVE exposure as it stood at the moment of impact
- (5) Containment evidence
 - Policy applied; flow drop counts; time-to-quarantine
- (6) Cross-border footprint
 - Destinations / origins outside the home Member State (informs Art. 23(2) cross-border indicator)

These six artefacts populate every phase of the Art. 23 flow without re-collecting data. The 24-hour early warning is short on detail by

design – the same six artefacts get progressively more complete by the 72-hour notification and the 1-month final report.

Evidence: Incident dossier per significant event; aggregate trend report fed into Art. 21(2)(f) effectiveness pack.

5. Article 21(2)(d) — Supply Chain Security (Technical Lens)

NIS2 supply-chain security is broader than DORA's third-party-risk pillar — it covers product suppliers, service providers, and the quality of the *direct supplier's* own cybersecurity practices.

CSW addresses the *what is my workload actually doing with my suppliers* question:

Step 1: Enumerate supplier-bound egress per in-scope service

CSW UI → Investigate → Flow Search

Filter: `source_scope = service=X AND destination_ip ∉ internal_ranges`

→ Group by destination FQDN/IP; rank by byte count, frequency

Step 2: Reconcile observed vs. supplier register

→ For every observed external destination, locate the corresponding entry in the supplier register

→ Flag missing / undocumented supplier endpoints

Step 3: Enforce supplier-egress allow-listing

ALLOW: in-scope workloads → {register-listed supplier endpoints}

DENY: in-scope workloads → all other external destinations

→ Run in Simulation; resolve gaps; promote to Enforce

Step 4: Continuous monitoring with management notification

→ CSW alert on new external destination from in-scope service

→ Routes to compliance / supplier-management function for register update under Art. 21(2)(d)

Evidence: Per-service supplier flow report; register-vs-observed delta; egress policy enforcement diff.

Caveat. A supplier's *internal* security posture remains contractual / questionnaire-based unless that supplier also runs CSW (or comparable workload telemetry) and shares evidence.

6. Article 20 — Governance Pack for the Management Body

Under Article 20(1), management bodies "approve the cybersecurity risk-management measures" and "supervise their implementation," and "can be held liable for infringements." Article 20(2) requires them to "follow training" so they have sufficient knowledge to assess the measures.

The simplest way for the body to discharge this is the **quarterly NIS2 pack**:

1. Asset-inventory drift summary (Art. 21(2)(i))
2. Segmentation policy diff and exception status (Art. 21(2)(a), (j))
3. Incident summary with MTTD/MTTR per service (Art. 21(2)(b))
4. Vulnerability backlog aged by severity (Art. 21(2)(e))
5. Supplier egress drift summary (Art. 21(2)(d))
6. Effectiveness metrics per measure (Art. 21(2)(f))
7. Open competent-authority findings and remediation status

This pack is the artefact a management body member can confidently sign-off on, and the artefact a competent authority will increasingly ask for as evidence of *operating effectiveness*, not just policy.

7. Mapping Table — NIS2 Measure → CSW Capability

NIS2 Provision	Requirement (paraphrased)	CSW Capability
Art. 20(1)	Management body accountability	Quarterly NIS2 pack (§6)
Art. 20(2)	Management body training	Pack section explanations are reusable training input
Art. 21(2)(a)	Risk analysis & IS security policies	Workspace export with policy Intents grounded in observed behaviour
Art. 21(2)(b)	Incident handling	Detection rules + SIEM forwarding + 6-artefact dossier
Art. 21(2)(c)	BCP / backup / crisis	Containment & forensic preservation only — backups are out of scope
Art. 21(2)(d)	Supply chain security	Supplier egress reconciliation (§5)
Art. 21(2)(e)	Sec. acquisition / dev / maintenance + vuln handling	Vulnerability inventory + CI/CD gate + CVE-to-attack-path
Art. 21(2)(f)	Effectiveness assessment	Quarterly effectiveness pack
Art. 21(2)(g)	Basic cyber hygiene + training	Patch & process telemetry; training out of scope
Art. 21(2)(h)	Cryptography /	Plaintext-protocol

NIS2 Provision	Requirement (paraphrased)	CSW Capability
	encryption	DENY enforcement (CSW does not provide crypto primitives)
Art. 21(2)(i)	HR sec. / access control / asset mgmt	Continuous inventory + label discipline (asset-mgmt part)
Art. 21(2)(j)	MFA / secured comms	Identity-based segmentation (workload-to-workload analogue)
Art. 23(1)	24-h early warning	6-artefact dossier (initial pass)
Art. 23(2)	72-h notification	Same dossier, progressively complete
Art. 23(3)	1-month final report	Same dossier, plus root-cause and remediation
Art. 32	Supervisory measures (essential entities)	Audit-ready exports on demand (§8)
Art. 33	Supervisory measures (important entities)	Same

8. Auditor / Competent-Authority Response Guide

When a competent authority or CSIRT asks for evidence:

Authority asks	You provide
"Show your in-scope asset inventory as of [date]"	CSW inventory snapshot filtered by <code>nis2_in_scope=true</code> , dated
"Demonstrate your segmentation between sensitive and public scopes"	Workspace export + Simulation showing zero allowed flows across the boundary
"Provide the incident timeline for event [ID]"	6-artefact dossier (§4)
"Show how Article 21(2)(d) supply-chain security is operating effectively"	Register-vs-observed delta (§5) + enforcement diff history
"Show effectiveness of your measures under Article 21(2)(f)"	Quarterly effectiveness pack (§6)
"Show the management body has reviewed measures under Article 20"	Pack with management-body sign-off cover sheet

9. Related Frameworks

NIS2 overlaps materially with:

- **DORA** — for financial-sector entities, DORA generally applies as *lex specialis* over NIS2 for the same control surface (see [DORA reference design](#)).
 - **ISO/IEC 27001:2022** — Annex A controls map closely to Art. 21(2) measures (see [ISO 27001 reference design](#)).
 - **NIST SP 800-207** — segmentation and continuous-monitoring expectations align with the seven ZTA tenets (see [800-207 reference design](#)).
 - **NIST SP 800-53** — for cross-jurisdiction programmes, 800-53 controls give a useful detailed mapping for Article 21(2)(e), (f), (i) (see [800-53 reference design](#)).
 - **UK NCSC CAF v3.2** — Art. 21(2)(a) and (d) are the reuse path for CAF A2 and A4 in a UK NIS OES or GovAssure assessment (see [CAF crosswalk](#)).
-

10. Disclaimer

This reference design describes how Cisco Secure Workload product capabilities can support a NIS2 programme. It is **not** legal, regulatory, or audit advice. NIS2 is implemented through Member State law that may add or refine requirements; classification as essential vs. important, incident significance thresholds, and supplier-related obligations are determined by your own management body and qualified counsel, working with the relevant national competent authority and CSIRT. Always validate against the latest implementing acts, ENISA guidance, and Member State transposition before formal use.